The Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011

UNION OF INDIA
India

The Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011

Rule
THE-INFORMATION-TECHNOLOGY-REASONABLE-SECURITY-PRACT of 2011

- Published on 11 April 2011
- Commenced on 11 April 2011
- [This is the version of this document from 11 April 2011.]
- [Note: The original publication document is not available and this content could not be verified.]

The Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011Published vide Notification New Delhi, the 11th April, 2011Ministry of Communications and Information Technology(Department of Information Technology)G.S.R. 313(E). - In exercise of the powers conferred by clause (ob) of sub-section (2) of section 87 read with section 43A of the Information Technology Act, 2000 (21 of 2000), the Central Government hereby makes the following rules, namely :-

1. Short title and commencement.

(1)These rules may be called the Information Technology (Reasonable security practices and procedures and sensitive personal date or information) Rules, 2011.(2)They shall come into force on the date of their publication in the Official Gazette

2. Definitions.

(1)In these rules, unless the context otherwise requires,-(a)"Act" means the Information Technology Act, 2000 (21 of 2000);(b)"Biometrics" means the technologies that measure and analyse human body characteristics, such as 'fingerprints', 'eye retinas and irises', 'voice patterns', 'facial patterns', 'hand measurements' and 'DNA' for authentication purposes;(c)"Body corporate" means the body

corporate as defined in clause (i) of explanation to section 43A of the Act;(d)"Cyber incidents" means any real or suspected adverse event in relation to cyber security that violates an explicitly or implicitly applicable security policy resulting in unauthorised access, denial of service or disruption, unauthorised use of a computer resource for processing or storage of information or changes to data, information without authorisation;(e)"Data" means data as defined in clause (o) of sub-section (1) of section 2 of the Act;(f)"Information" means information as defined in clause (v) of sub-section (1) of section 2 of the Act;(g)"Intermediary" means an intermediary as defined in clause (w) of sub-section (1) of section 2 of the Act;(h)"Password" means a secret word or phrase or code or passphrase or secret key, or encryption or decryption keys that one uses to gain admittance or access to information;(i)"Personal information" means any information that relates to a natural person, which, either directly or indirectly, in combination with other information available or likely to be available with a body corporate, is capable of identifying such person.(2)All other words and expressions used and not defined in these rules but defined in the Act shall have the meanings respectively assigned to them in the Act.

3. Sensitive personal data or information.

- Sensitive personal data or information of a person means such personal information which consists of information relating to;-(i)password;(ii)financial information such as Bank account or credit card or debit card or other payment instrument details;(iii)physical, physiological and mental health condition;(iv)sexual orientation;(v)medical records and history;(vi)Biometric information;(vii)any detail relating to the above clauses as provided to body corporate for providing service; and(viii)any of the information received under above clauses by body corporate for processing, stored or processed under lawful contract or otherwise:provided that, any information that is freely available or accessible in public domain or furnished under the Right to Information Act, 2005 or any other law for the time being in force shall not be regarded as sensitive personal data or information for the purposes of these rules.

4. Body corporate to provide policy for privacy and disclosure of information.

(1)The body corporate or any person who on behalf of body corporate collects, receives, possess, stores, deals or handle information of provider of information, shall provide a privacy policy for handling of or dealing in personal information including sensitive personal data or information and ensure that the same are available for view by such providers of information who has provided such information under lawful contract. Such policy shall be published on website of body corporate or any person on its behalf and shall provide for-(i)clear and easily accessible statements of its practices and policies;(ii)type of personal or sensitive personal data or information collected under rule 3;(iii)purpose of collection and usage of such information;(iv)disclosure of information including sensitive personal data or information as provided in rule 6;(v)reasonable security practices and procedures as provided under rule 8.

5. Collection of information.

(1)Body corporate or any person on its behalf shall obtain consent in writing through letter or fax or email from the provider of the sensitive personal data or information regarding purpose of usage before collection of such information.(2)Body corporate or any person on its behalf shall not collect sensitive personal data or information unless -(a)the information is collected for a lawful purpose connected with a function or activity of the body corporate or any person on its behalf; and(b)the collection of the sensitive personal data or information is considered necessary for that purpose.(3)While collecting information directly from the person concerned, the body corporate or any person on its behalf shall take such steps as are, in the circumstances, reasonable to ensure that the person concerned is having the knowledge of -(a)the fact that the information is being collected;(b)the purpose for which the information is being collected;(c)the intended recipients of the information; and(d)the name and address of -(i)the agency that is collecting the information; and(ii)the agency that will retain the information.(4)Body corporate or any person on its behalf holding sensitive personal data or information shall not retain that information for longer than is required for the purposes for which the information may lawfully be used or is otherwise required under any other law for the time being in force.(5)The information collected shall be used for the purpose for which it has been collected.(6)Body corporate or any person on its behalf shall permit the providers of information, as and when requested by them, to review the information they had provided and ensure that any personal information or sensitive personal data or information found to be inaccurate or deficient shall be corrected or amended as feasible:provided that a body corporate shall not be responsible for the authenticity of the personal information or sensitive personal data or information supplied by the provider of information to such body corporate or any other person acting on behalf of such body corporate.(7)Body corporate or any person on its behalf shall, prior to the collection of information including sensitive personal data or information, provider an option to the provider of the information to not to provide the data or information sought to be collected. The provider of information shall, at any time while availing the services or otherwise; also have an option to withdrawal its consent given earlier to the body corporate. Such withdrawal of the consent shall be sent in writing to the body corporate. In the case of provider of information not providing or later on withdrawing his consent, the body corporate shall have the option not to provide goods or services for which the said information was sought.(8)Body corporate or any person on its behalf shall keep the information secure as provided in rule 8.(9)Body corporate shall address any discrepancies and grievances of their provider of the information with respect to processing of information in a time bound manner. For this purpose, the body corporate shall designate a Grievance Officer and publish his name and contact details on its website. The Grievance Officer shall redress the grievances of provider of information expeditiously but within one month from the date of receipt of grievance.

6. Disclosure of information.

(1)Disclosure of sensitive personal data or information by body corporate to any third party shall require prior permission from the provider of such information, who has provided such information under lawful contract or otherwise, unless such disclosure has been agreed to in the contract between the body corporate and provider of information, or where the disclosure is necessary for

compliance of a legal obligation:Provided that the information shall be shared, without obtaining prior consent from provider of information, with Government agencies mandated under the law to obtain information including sensitive personal data or information for the purpose of verification of identity, or for prevention, detection, investigation including cyber incidents, prosecution, and punishment of offences. The Government agency shall send a request in writing to the body corporate possessing the sensitive personal data or information stating clearly the purpose of seeking such information. The Government agency shall also state that the information so obtained shall not be published or shared with any other person.(2)Notwithstanding anything contained in sub-rule (1), any sensitive personal data or Information shall be disclosed to any third party by an order under the law for the time being in force.(3)The body corporate or any person on its behalf shall not publish the sensitive personal data or information.(4)The third party receiving the sensitive personal data or information from body corporate or any person on its behalf under sub-rule (1) shall not disclose it further.

7. Transfer of information.

- A body corporate or any person on its behalf may transfer sensitive personal data or information including any information, to any other body corporate or a person in India, or located in any other country, that ensures the same level of data protection that is adhered to by the body corporate as provided for under these Rules. The transfer may be allowed only if it is necessary for the performance of the lawful contract between the body corporate or any person on its behalf and provider of information or where such person has consented to data transfer.

8. Reasonable Security Practices and Procedures.

(1)A body corporate or a person on its behalf shall be considered to have complied with reasonable security practices and procedures, if they have implemented such security practices and standards and have a comprehensive documented information security programme and information Security policies that contain managerial, technical, operational and physical security control measures that are commensurate with the information assets being protected with the nature of business. In the event of an information security breach, the body corporate or a person on its behalf shall be required to demonstrate, as and when called upon to do so by the agency mandated under the law, that they have implemented security control measures as per their documented information security programme and information security policies.(2)The international Standard IS/ISO/IEC 27001 on "Information Technology-Security Techniques - Information Security Management System - Requirements" is one such standard referred to in sub-rule (1).(3)Any industry association or an entity formed by such an association, whose members are self-regulating by following other than IS/ISO/IEC codes of best practices for data protection as per sub-rule (1), shall get its codes of best practices duly approved and notified by the Central Government for effective implementation.(4)The body corporate or a person on its behalf who have implemented either IS/ISO/IEC 27001 standard or the codes of best practices for data protection as approved and notified under sub-rule (3) shall be deemed to have complied with reasonable security practices and procedures provided that such standard or the codes of best practices have been certified or audited on a through independent auditor, duly approved by the Central Government. The audit of

reasonable security practices and procedures shall be carried out by an auditor at least once a year or as and when the body corporate or a person on its behalf undertake significant upgradation of its process and computer resource.